

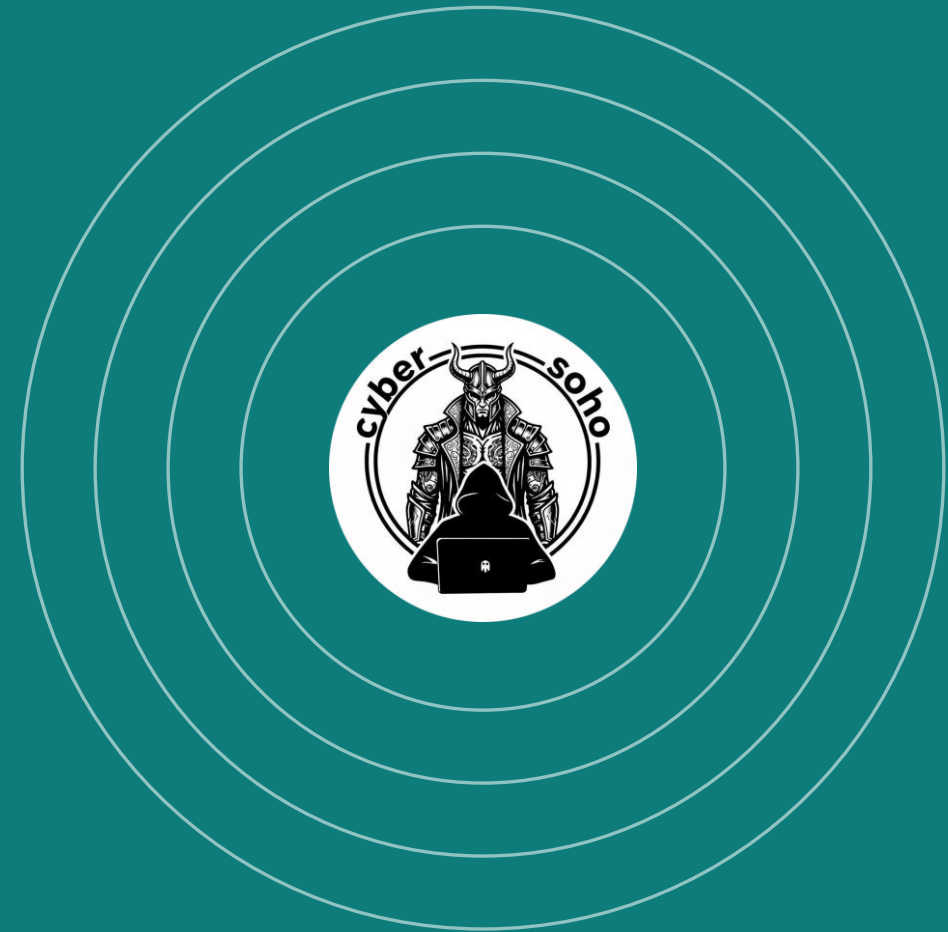
CS 474 · COMPUTER SECURITY · CLASS 1

Kick-off: Welcome & Introduction to Computer Security

Thursday, September 24, 2026 · Hour 1 — five short lessons, 60 minutes

CS (Computer Science) 474 · Foundations of Computer Security · LO (Learning Outcome) 1
Reading: Easttom, *Computer Security Fundamentals* (4th ed.), chapter 1

Cyber.SoHo — Educational Hub



Before we start: authorization first

CLASS 1 · HOUR 1

1

2

3

4

5

The one rule that makes everything in this course lawful

§

No permission, no testing.

Authorization is the only thing that separates a security test from a crime.

- Every scan, test or “attack” in this course happens **only** on the designated lab systems and the fictional **BlueFern Trading Inc.** scenario — with explicit authorization.
- The same action on any other system is a **criminal offence**, whatever the intention: Canadian Criminal Code s. 342.1 · **US** (United States) **CFAA** (Computer Fraud and Abuse Act), 18 U.S.C. § 1030 · **EU** (European Union) Directive 2013/40/EU · Spain, Ley Orgánica 10/1995.
- Never test a system you do not own or do not have **written** permission to test.
- No **OSINT** (Open-Source Intelligence) on real people or real organizations — ever.
- Not sure you are authorized? Then you are not. **Stop and ask.**

Full rules: [Cyber.SoHo Legal Notice, Terms of Use & Acceptable Use Policy \(v2.0\)](#) — you sign your acknowledgement before the first laboratory (form provided separately).



Today's hour at a glance

CLASS 1 · HOUR 1

1 2 3 4 5

Five short lessons · 60 minutes · every lesson ends with a short activity

1 0:00 – 0:12

Welcome, who we
are & how this course
works

Activity
The asset wall

2 0:12 – 0:24

Security vocabulary
through one story

Activity
Match the six terms

3 0:24 – 0:36

Confidentiality,
integrity, availability
& the four checks of a
login

Activity
Six headlines: C, I or A?

4 0:36 – 0:46

A first tour of the
threat landscape

Activity
Which family?

5 0:46 – 1:00

Security as a process,
defence in depth, legal
basics & logistics

Activity
Fun quiz + Zen break

The path of every lesson



Self-checks are **formative**: for practice only — they do not count toward your grade.



Welcome to CS 474

LESSON 1

0:00 – 0:12

1

2

3

4

5

What you will be able to do by January — and why it matters to a software engineer

By January you will be able to

1

look at a computer system and describe **what can go wrong**

2

estimate **how badly** it can go wrong

3

decide **what to fix first**

Why a software engineer needs this

- Most incidents begin with a **software defect** or a **human decision** — you will write the software and make the decisions.
- Security **designed in** costs less than security added after an incident: a design decision is cheap on paper and expensive in production.
- The **law** holds organizations — and individuals — accountable (Lesson 5).

i

Attack surface — the set of all points where an unauthorized person can try to enter data into a system or extract data from it: input fields, open network ports, login pages, file uploads. The code you write becomes an asset — and an attack surface — the moment it runs in production.



Three words, three meanings

LESSON 1

0:00 – 0:12

1

2

3

4

5

Precise words are the first tool of this discipline

Computer security is the protection of computer systems, and of the information they store, process and transmit, against unauthorized **access, modification, disclosure, disruption** and **destruction**.

i

Information security

Protects information in **any form**: digital files, paper records and the knowledge in people's heads.

the widest scope

C

Computer security

Protects the **machines**, the **software** that runs on them and the **data** they hold.

CS 474 — this course

cy

Cybersecurity

Protects **networked** digital systems, from a phone to a power grid.

the networked world

CS 474 is a **computer-security** course — not a cybersecurity course. Job postings mix the three words; this course keeps them apart.



Your turn: the ice-breaker

4 minutes — everybody speaks once

LESSON 1

0:00 – 0:12

1

2

3

4

5



Your name — and the one device or the one set of data you would hate to lose.

20 s

20 seconds each: your name and one device or one set of data.

3

More than 30 people? Teams of three; each team reports three items.

all

Every answer goes on the board, unsorted — we sort the board at the end of this lesson.

Typical answers

my phone

my thesis folder

my photos

my bank login

my gaming account

my laptop



How this course works (1/2)

Fifteen Thursdays · the 1:2:2 rhythm · one company for the whole term

LESSON 1

0:00 – 0:12

1

2

3

4

5

Every Thursday: the 1:2:2 rhythm

1 h

lecture, in short
parts like this one

2 h

guided project work
in class, in teams

2 h

at home, on the
same project

Each week

one Binder Part

your Project Binder

15 Thursdays, from September 24 to January 21. The Binder Parts are the project — one piece of work per week.

The company: BlueFern Trading Inc.

A small online retailer of hiking gear — **fictional on purpose**.

38

people

1

web shop

1

office

1

warehouse

- A long list of **deliberate weaknesses** — you discover them one at a time.
- You **assess** the company, then **defend** it, for the whole term.



How this course works (2/2)

LESSON 1
0:00 – 0:12



The one FACT to remember from today



Your weekly work is not homework on the side. It is the project — and the project is your exam preparation.

WED 23:59

every Binder Part is due the Wednesday before the next class

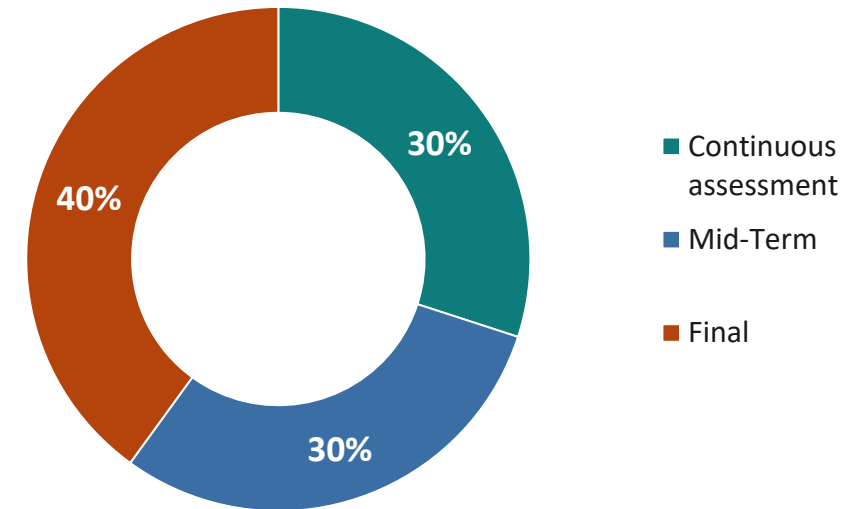
NOV 19

Milestone 1 — the Mid-Term (Thursday)

JAN 21

Milestone 2 — the Final (Thursday)

Assessment weights



The Mid-Term and the Final use **the same company** and the same kinds of computations and decisions you practise every week.



The asset wall: five categories

LESSON 1

0:00 – 0:12

1

2

3

4

5

Micro-activity (4 min) — we sort the board together

1

Look at the board: your answers, unsorted.

2

Sort them into **hardware, software, data, people, process**.

3

Disagree with a placement? Say so — and why.

4

The result is an **asset inventory**: the first document of every security assessment.

From the asset wall to Binder Part 1

Five asset categories of BlueFern Trading Inc. (fictional) - Lesson 1

Hardware	Software	Data	People	Process
- Web-shop cloud VM - Windows file server - 30 staff laptops - POS terminal and 6 barcode scanners - Office network / Wi-Fi	- Custom PHP web shop - MySQL database engine - Operating systems - Cloud e-mail service	- Customer records (about 120,000) - HR and finance folders - Order history - Backup USB drive	- 2 IT staff - 2 developers - 38 staff who log in - Customers' trust	- Weekly backup routine - Password handling - Joiner / leaver steps - Patching (none since 2023)

Ice-breaker

"the one device or data I would hate to lose"

Asset wall

answers grouped into 5 categories

Asset inventory

Exercise 1.1 -> Binder Part 1 (Sep 30)

Reused later

Parts 4, 6 and 8

One row per asset: name | category | owner (role) | location | impact if C / I / A is lost (Low - Medium - High) | why

You cannot protect what you have not listed - the inventory is the first document of every security assessment.

Cyber.SoHo - CS 474 Class 1 - Lesson 1



BlueFern's first asset inventory

LESSON 1

0:00 – 0:12

1

2

3

4

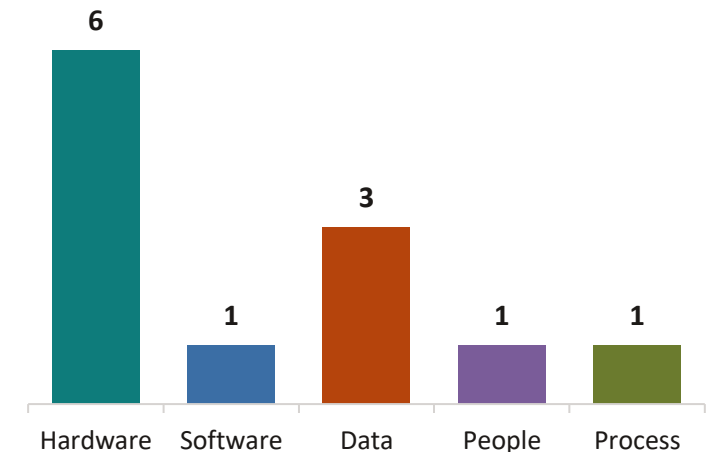
5

Twelve assets · owner · impact if confidentiality (C), integrity (I) or availability (A) is lost

#	Asset	Category	Owner (role)	C	I	A
1	Web-shop server (cloud virtual machine)	Hardware	IT staff	M	H	H
2	Customer database (~120,000 records)	Data	Head of Sales	H	H	M
3	Custom web-shop code	Software	Developers	M	H	H
4	Windows file server (HR, finance)	Hardware	IT staff	H	H	M
5	HR and finance folders	Data	CFO	H	H	M
6	30 staff laptops (no disk encryption)	Hardware	IT staff	H	M	M
7	Showroom POS terminal	Hardware	Head of Sales	M	H	H
8	6 warehouse barcode scanners	Hardware	Warehouse lead	L	M	H
9	Office network and Wi-Fi (one SSID)	Hardware	IT staff	M	M	H
10	Backup USB drive (weekly, untested)	Data	IT staff	H	H	H
11	2 IT staff (know every system)	People	COO	M	M	H
12	Backup process ("whoever remembers")	Process	COO	L	H	H

H = High · M = Medium · L = Low · **IT** (Information Technology) · **HR** (Human Resources) · **CFO** (Chief Financial Officer) · **COO** (Chief Operating Officer) · **POS** (Point of Sale) · **SSID** (Service Set Identifier) · **USB** (Universal Serial Bus)

Assets per category



All 12 assets have at least one **High** rating; integrity and availability are High for 8 assets each, confidentiality for 5.

Exercise 1.1 → Binder Part 1, due Wednesday, September 30, 23:59.



Real-life example: the asset inventory

LESSON 1
0:00 – 0:12



The consultant's first hour at BlueFern — and your Exercise 1.1

The task

Turn the list of things people care about — the ice-breaker answers, then the BlueFern profile — into rows of an **asset inventory**: category, owner, location, and the impact (Low · Medium · High) of losing C, I or A.

How it relates

What an **asset** is, and why the **asset inventory** is the first document of every security assessment; the impact ratings preview Lesson 3.

Where it returns

Exercise 1.1 → **Binder Part 1** (due Wednesday, September 30, 23:59) · reused in Part 4 (what to scan first), Part 6 (the risk register) and Part 8 (the target architecture).



Try it: examples/L1_asset_inventory_builder.html — Start · Pause · Restart · Download CSV (Comma-Separated Values)

Asset Inventory Builder - from the "asset wall" to Binder Part 1

Each step takes one asset of BlueFern Trading Inc., classifies it (hardware, software, data, people, process), names an owner and rates the impact of losing Confidentiality (C), Integrity (I) and Availability (A). Pause at any step to discuss it.

[Start](#) [Restart](#) [Copy log](#) [Copy code](#) [Download inventory \(CSV\)](#)

Finished - the wall is now an asset inventory.

Asset wall (cards are coloured by category)

#1 Web-shop server (cloud VM: Linux, Apache, MySQL, PHP) Hardware - owner: IT staff C:M I:H A:H	#2 Customer database (~120,000 records) Data - owner: Head of Sales C:H I:H A:M	#3 Custom PHP web-shop code Software - owner: Developers C:M I:H A:H
#4 Windows file server (HR, finance, photos) Hardware - owner: IT staff C:H I:H A:M	#5 HR and finance folders Data - owner: CFO C:H I:H A:M	#6 30 staff laptops (Windows 10/11, no disk encryption) Hardware - owner: IT staff C:H I:M A:M
#7 Showroom POS terminal Hardware - owner: Head of Sales C:H I:H A:H	#8 6 warehouse barcode scanners Hardware - owner: Warehouse lead C:L I:M A:H	#9 Office network and Wi-Fi (single shared SSID) Hardware - owner: IT staff C:M I:M A:H
#10 Backup USB drive (weekly, untested) Data - owner: IT staff C:H I:H A:H	#11 2 IT staff (know every system) People - owner: COO C:M I:M A:H	#12 Backup process (‘whoever remembers’, weekly) Process - owner: COO C:L I:H A:H

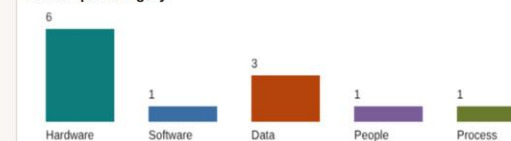
Execution steps (read this window when paused)

MESSAGE
impact if lost: C=Medium, I=Medium, A=High
why: If both are unavailable, nobody can restore or fix anything.

Step 12: ‘Backup process (‘whoever remembers’, weekly)’
category = Process | owner = COO | location = Undocumented
impact if lost: C=Low, I=High, A=High
why: An unreliable process is an asset with a built-in weakness.

Done. 12 assets inventoried; 12 of them have at least one High impact rating.
This table is the core of Binder Part 1 (due Wednesday, September 30, 23:59).

Assets per category



Review & watch — Lesson 1

LESSON 1
0:00 – 0:12



Five key terms — cover the definition, say it, then check

1 Computer security

The protection of computer systems and of the information they store, process and transmit against unauthorized access, modification, disclosure, disruption and destruction.

2 Asset

Anything of value to an organization that needs protection: hardware, software, data, people or a process.

3 Asset inventory

A structured list of assets with, for each one, its category, its owner and the impact of losing its confidentiality, integrity or availability. The first document of every security assessment.

4 Attack surface

The set of all points where an unauthorized person can try to enter data into a system or extract data from it - inputs, open ports, login pages, uploads.

5 The one FACT

The weekly Binder Parts ARE the project, and the project IS the exam preparation: the Mid-Term (Nov 19) and the Final (Jan 21) are milestones of the same BlueFern project. Parts are due Wednesdays, 23:59.



Watch — under 15 min

[Cybersecurity - Crash Course Computer Science #31](#)

Crash Course / PBS (Public Broadcasting Service) Digital Studios (Carrie Anne Philbin) · about 12 min



Self-check — Lesson 1 (1/2)

LESSON 1

0:00 – 0:12

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

1

MCQ (Multiple-Choice Question) — one answer

Which statement best defines computer security as used in this course?

- a) Installing antivirus software on every computer of the organization
- b) The study of how attackers write malicious software
- c) The protection of computer systems and of the information they store, process and transmit against unauthorized access, modification, disclosure, disruption and destruction
- d) The set of laws that regulate the protection of personal data

2

MCQ — one answer

Which of the following BlueFern items is a 'process' asset?

- a) The Windows file server
- b) The weekly backup routine ('whoever remembers')
- c) The customer database
- d) The two IT (Information Technology) staff

3

MCQ — one answer

What does 'the one FACT' of this course state?

- a) The Binder is optional homework that does not influence the exams
- b) The exams cover only the textbook chapters
- c) The Binder is graded only once, at the end of the term
- d) The Mid-Term and the Final are milestones of the same project as the weekly Binder Parts, so the Binder is the exam preparation

4

MCQ — one answer

When is each Binder Part due?

- a) Wednesday, 23:59, before the next Thursday class
- b) Thursday morning, at the start of the class
- c) Friday at noon, the day after the class
- d) Only at the milestone dates (November 18 and January 13)



Self-check — Lesson 1 (2/2)

LESSON 1

0:00 – 0:12

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

5

MSQ (Multiple-Select Question) — select 3

Which of the following are assets of BlueFern Trading Inc.? (3)

- a) The fact that one administrator password is shared by the router, the file server and the web-shop admin panel
- b) The customer database of about 120,000 records
- c) The attacker scanning the Internet for old **FTP** (File Transfer Protocol) versions
- d) The ransom note left on the file server
- e) The two **IT** (Information Technology) staff who know every system
- f) The showroom **POS** (Point of Sale) terminal

6

MSQ — select 4

Which columns belong in one row of the asset inventory you will build in Exercise 1.1? (4)

- a) The asset's name
- b) The name of the attacker who might target it
- c) Its category (hardware, software, data, people, process)
- d) Its owner (a role)
- e) The exploit code that could be used against it
- f) The impact of losing its confidentiality, integrity and availability (Low / Medium / High)



Monday, 07:40: the web shop is defaced

LESSON 2

0:12 – 0:24

1

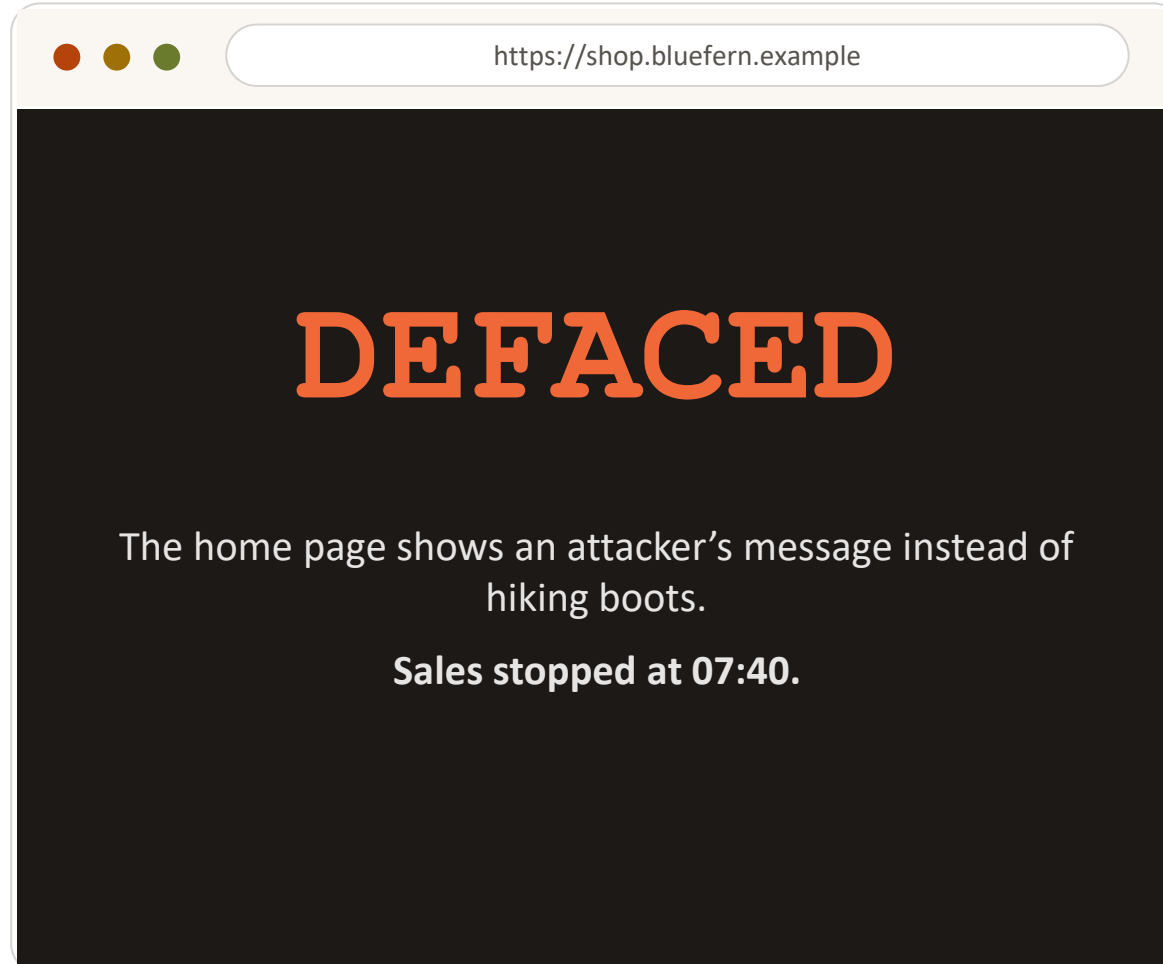
2

3

4

5

Lesson 2 — the vocabulary of the discipline, placed on one event



- **07:40** — the first customer of the day opens shop.bluefern.example and sees a black page with an attacker's message.
- Sales stop. The two **IT** (Information Technology) staff are called, then the **CEO** (Chief Executive Officer); nobody knows yet what happened.
- **Defacement** — the unauthorized replacement of a website's visible content.
- Next ten minutes: **six terms**, one event — the vocabulary of the whole discipline.



Six terms, one story (1/2)

LESSON 2

0:12 – 0:24

1

2

3

4

5

Asset · vulnerability · threat

1 Asset

Something of value to the organization that needs protection.

In the story

The web-shop server — and through it the sales (about \$3,000 per hour of downtime), about 120,000 customer records and the company's reputation.

2 Vulnerability

A weakness in an asset — in its design, implementation, configuration or operation — that could be used to cause harm. It exists even when nobody attacks.

In the story

The **FTP** (File Transfer Protocol) service vsftpd 2.3.4, with a public backdoor listed in the **CVE** (Common Vulnerabilities and Exposures) catalogue as CVE-2011-2523, open to the Internet; last patched in 2023; one shared admin password.

3 Threat

A possible cause of harm to an asset. The person or thing behind it is the **threat agent** (or threat actor).

In the story

An opportunistic attacker scanning the Internet for old FTP versions: port 21 open, the vulnerable version shown in the banner. A threat needs a vulnerability to become harm.



Six terms, one story (2/2)

LESSON 2

0:12 – 0:24

1

2

3

4

5

Exploit & attack · risk · control & residual risk

4 Exploit

The specific method — code, inputs or a procedure — that takes advantage of a vulnerability. Its use against the asset is the **attack**; once noticed and handled, a **security incident**.

In the story

The input that triggers the backdoor and returns a command shell; with it, the attacker replaces the home page.

5 Risk

Risk = likelihood × impact, each rated from 1 to 5 today; in Class 6 both become money.

In the story

Likelihood 5 (public flaw, automated scanners) × impact 4 (about six hours offline, customers misled) = **20 of 25 — critical**.

6 Control

A measure that reduces likelihood, impact or both: **preventive**, **detective** or **corrective** (also: countermeasure, safeguard).

In the story

Remove **FTP** (File Transfer Protocol), patch, one password per system (preventive); login logs (detective); tested off-line backups (corrective). **Residual risk** $1 \times 2 = 2$ — never zero.



Two confusions to avoid

Students mix up two pairs of terms

Vulnerability ≠ threat

IN

Vulnerability — *in* the asset: the old **FTP** (File Transfer Protocol) version on the web-shop server.

OUT

Threat — *outside* the asset: the scanner, and the person behind it.

A threat needs a vulnerability to become harm: a server that exposes no weakness is not harmed by a scanner that probes it.

Risk ≠ impact

$$\text{risk} = \text{likelihood} \times \text{impact}$$

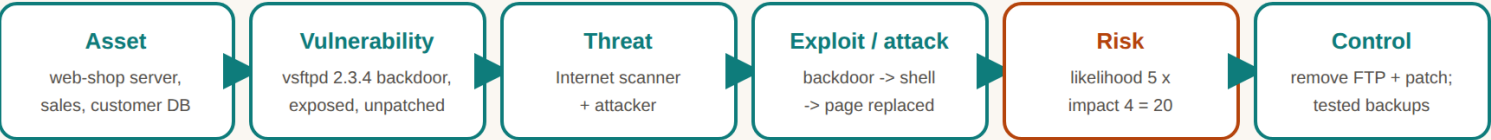
- **Impact** — what happens *if* the event occurs.
- **Risk** — that impact combined with how *likely* the event is.
- A meteorite hitting the **IT** (Information Technology) closet: impact very high, likelihood negligible → risk low. Nobody buys a meteorite shield.

The vocabulary chain and the risk matrix

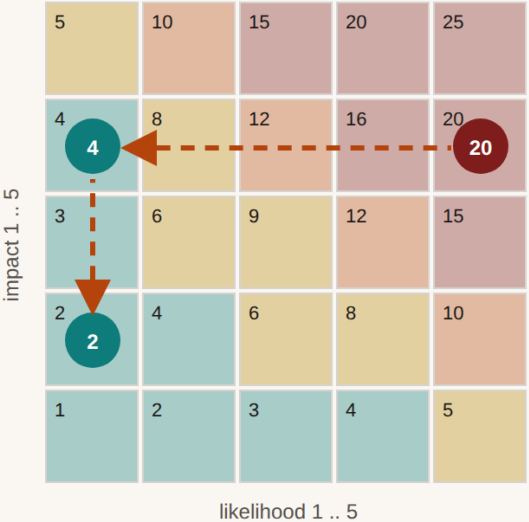
The defacement before and after two controls

The vocabulary chain - one incident, six terms

The BlueFern web-shop defacement (Lesson 2)



Risk matrix: risk = likelihood x impact (1-5 each)



Before controls

likelihood 5 (public flaw, automated scanners) x impact 4 (6 h outage) = 20 - critical

Control 1 - preventive: remove FTP, SFTP over SSH via VPN, patch

likelihood 5 -> 1: risk 1 x 4 = 4 - low

Control 2 - corrective: tested off-line backups (restore in 1 h)

impact 4 -> 2: residual risk 1 x 2 = 2 - low

Bands:

Low 1-4

Medium 5-9

High 10-14

Critical 15-25

Residual risk is never zero: accepting it is a management decision.

Class 6 attaches money: SLE = AV x EF, ALE = SLE x ARO.

How to read it

- Top row: the six terms, in the order the story uses them.
- Matrix: likelihood 1–5 across, impact 1–5 up; the colour is the band.
- **20** — before any control: critical.
- Preventive control → likelihood 1 → **4**, low.
- Corrective control (tested backups) → impact 2 → residual risk **2**.

Your turn: match the six terms

LESSON 2

0:12 – 0:24

1

2

3

4

5

Micro-activity (4 min) — say each definition in your own words first, then match

A Asset

1 A measure that reduces risk by lowering its likelihood, its impact or both.

B Vulnerability

2 A weakness in design, implementation, configuration or operation that could be used to cause harm.

C Threat

3 The likelihood that a threat exploits a vulnerability, combined with the impact if it does.

D Exploit

4 Something of value to the organization that needs protection.

E Risk

5 The specific method — code, inputs or a procedure — that takes advantage of a vulnerability.

F Control

6 A possible cause of harm to an asset; the person or thing behind it is its agent.



Watch (under 15 min): [Security Concepts - CompTIA Network+ N10-008 - 4.1](#)

Professor Messer (Messer Studios) · 9:21



Real-life example: one row of a risk register

LESSON 2

0:12 – 0:24

1

2

3

4

5

From the defacement story to Binder Part 6

The task

Write the defacement as one record — asset, vulnerability, threat, exploit / attack, risk (likelihood × impact) and controls — then compute the residual risk.

How it relates

The six definitions of this lesson on one event; risk becomes a number, before and after controls.

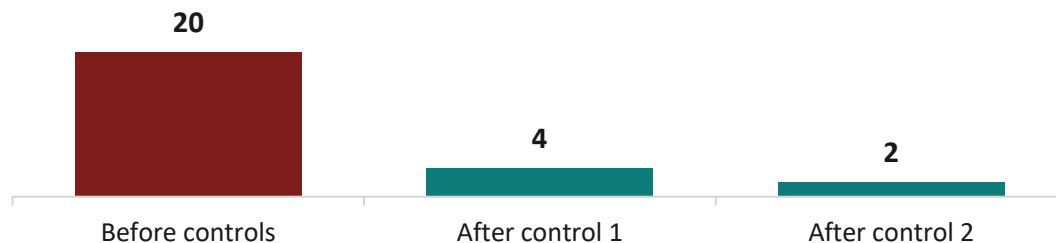
Where it returns

Exercise 1.2 this afternoon · the **risk register** of Binder Part 6 (with money: **SLE** (Single Loss Expectancy), **ARO** (Annualized Rate of Occurrence), **ALE** (Annualized Loss Expectancy)) · the vsftpd finding in Binder Part 4.



Try it: examples/L2_vocabulary_chain_simulator.html — Start · Pause · Download CSV (Comma-Separated Values)

Risk score (likelihood × impact)



Vocabulary chain - the BlueFern web-shop defacement, one term at a time

The six terms of Lesson 2 are placed on one incident: asset, vulnerability, threat, exploit, risk, control. The 5x5 matrix shows the risk score (likelihood × impact) before and after two controls.

Start

Restart

Copy log

Copy code

Download risk-register row (CSV)

Finished - press Restart to run again.

The vocabulary chain



Risk matrix (likelihood 1-5 across, impact 1-5 up)

Risk score: 2 (Low band: 1 × 2)

	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5
likelihood 1 .. 5					

Execution steps

transfer files with SFTP over SSH restricted to the VPN, and patch the server. Likelihood falls from 5 to 1: risk = 1 × 4 = 4 -> Low band.

Step 7 - CONTROL 2 (corrective): tested off-line backups restore the site in 1 hour instead of 6. Impact falls from 4 to 2: risk = 1 × 2 = 2 -> Low band.

Step 8 - RESIDUAL RISK = 2. This is the value that goes into the risk register (Binder Part 6) with the asset, the vulnerability, the threat and the chosen controls.

Done. Same asset, same threat - two controls turned a Critical risk (20) into a Low residual risk (2). Prevention lowers likelihood; recovery lowers impact.



Self-check — Lesson 2 (1/2)

LESSON 2

0:12 – 0:24

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

1

MCQ (Multiple-Choice Question) — one answer

In the defacement story, 'vsftpd 2.3.4 with a publicly known backdoor, reachable from the Internet' is a:

- a) Threat
- b) Vulnerability
- c) Risk
- d) Control

2

MCQ — one answer

Which sentence describes risk correctly?

- a) Any attack that has happened to the organization
- b) The combination of the likelihood that a threat exploits a vulnerability and the resulting impact
- c) The cost of the firewall that protects the network
- d) The list of all vulnerabilities found by a scanner

3

MCQ — one answer

An exploit is:

- a) The person who carries out an attack
- b) A weakness in software or in its configuration
- c) The specific method or code that takes advantage of a vulnerability
- d) The damage measured after an attack

4

MCQ — one answer

Which control reduces the **LIKELIHOOD** of the defacement rather than its impact?

- a) Tested off-line backups that restore the site in one hour
- b) Buying cyber-insurance
- c) Publishing an apology to customers after the incident
- d) Removing the **FTP** (File Transfer Protocol) service and patching the server



Self-check — Lesson 2 (2/2)

LESSON 2

0:12 – 0:24

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

5

MSQ (Multiple-Select Question) — select 3

Which items from the BlueFern company profile are vulnerabilities? (3)

- a) The customer database of about 120,000 records
- b) MySQL reachable from the Internet
- c) A competitor that recently launched a similar product line
- d) Staff laptops without disk encryption
- e) Annual revenue of about \$6 million
- f) One shared administrator password for the router, the file server and the web-shop admin panel

6

MSQ — select 2

Which statements are correct? (2)

- a) A vulnerability causes damage by itself, even when no threat exists
- b) Well-chosen controls eliminate all risk
- c) A threat needs a vulnerability to cause harm
- d) Risk equals impact only
- e) Residual risk is the risk that remains after controls have been applied
- f) An exploit is a type of asset



The CIA triad

LESSON 3

0:24 – 0:36

1

2

3

4

5

CIA (Confidentiality, Integrity and Availability) — three properties every secure system must keep



Confidentiality

Definition: information is not disclosed to unauthorized persons, processes or systems.

Failure: disclosure — a leak.

At BlueFern: about 120,000 customer records; **HR** (Human Resources) and finance folders that everyone can read today.

Protected by: encryption (on disk; in transit with **HTTPS** (HyperText Transfer Protocol Secure)), access control, authentication.



Integrity

Definition: information is accurate and complete, and has not been altered without authorization.

Failure: unauthorized **modification**.

At BlueFern: prices changed; an order total altered from \$129.90 to \$1.90; refunds paid twice.

Protected by: hashing (for example **SHA-256** (Secure Hash Algorithm, 256-bit)), digital signatures, access control.



Availability

Definition: a system and its data are accessible and usable, on demand, by authorized users.

Failure: disruption — down, or too slow to use.

At BlueFern: about \$3,000 per hour of downtime — about \$25,000 per hour in Black Friday week.

Protected by: redundancy, capacity planning, tested backups, denial-of-service protection.

One event can break more than one property. Ransomware on the file server: availability first; confidentiality too if the files were copied before encryption. Name the **primary** failure first.



Four checks behind every login

LESSON 3

0:24 – 0:36

1

2

3

4

5

Identification → authentication → authorization → accounting = non-repudiation

1

Identification

the **claim**: “I am m.tremblay.” A username identifies; it proves nothing.

2

Authentication

the **proof** of the claim, with one or more factors. BlueFern today: no **MFA** (Multi-Factor Authentication) anywhere, one shared admin password.

3

Authorization

what the verified identity **may do**. Rule: **least privilege**; tool: **RBAC** (Role-Based Access Control) — BlueFern’s role matrix in Class 2.

4

Accounting

the **record** of who did what, and when, in logs the person cannot edit (also called accountability).

=

Non-repudiation — a party cannot later deny having performed an action. It comes from authentication + accounting + a **digital signature**: when m.tremblay’s refund approval at 14:32 is logged and signed, she cannot credibly say “that was not me”.

Authentication factors

KNOW

something you **know** — a password, a PIN

HAVE

something you **have** — a phone app, a hardware key

ARE

something you **are** — a fingerprint, a face

Two **different types** = MFA. Two passwords are still one factor.

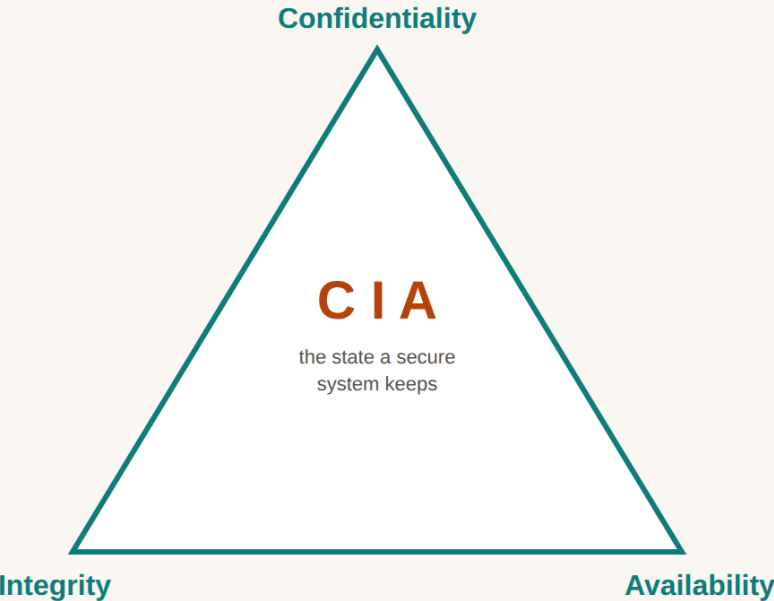


The CIA triad and the four checks

Three properties of the data — four checks when someone asks for access

The CIA triad and the four checks of a login

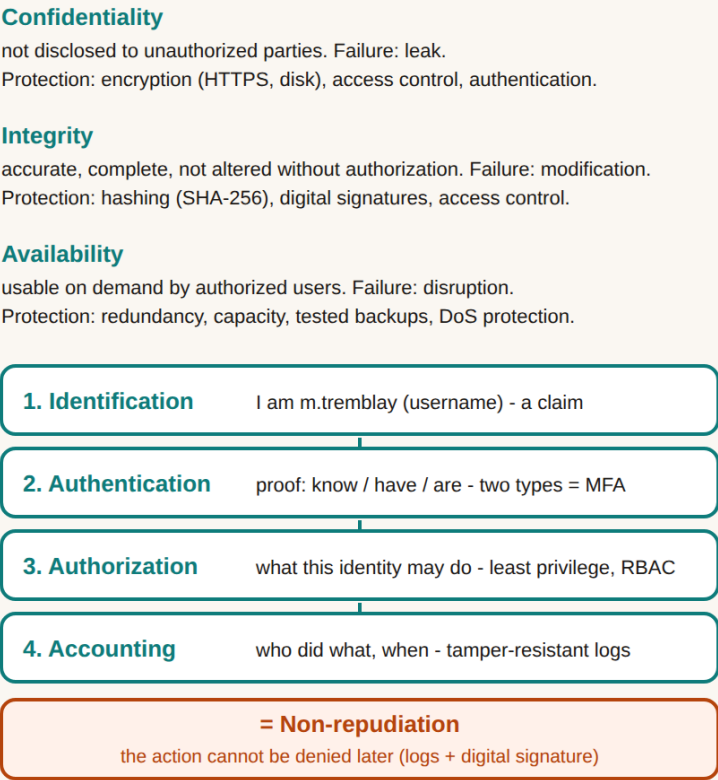
Three properties of the data - four checks when someone asks for access (Lesson 3)



One event can break more than one property:
ransomware = availability (primary) + integrity (+ confidentiality if files were copied first).

Six-headline drill: name the PRIMARY property first, then the secondary one.

Cyber.SoHo - CS 474 Class 1 - Lesson 3



How to read it

- Triangle: the three **CIA** (Confidentiality, Integrity and Availability) properties a secure system keeps.
- Right, top: definition, failure and protection of each property.
- Right, bottom: the four checks of a login, in the order they happen.
- Rust box: together they give **non-repudiation**.
- Bottom left: one event can break more than one property — name the primary one first.

Your turn: six headlines — C, I or A?

LESSON 3

0:24 – 0:36

1

2

3

4

5

Micro-activity (4 min) · fictional headlines — hands up for the PRIMARY property, then name a second one

1

“Retailer's customer list posted on a public forum”

C

I

A

2

“Attacker changed prices in the online catalogue overnight”

C

I

A

3

“Web shop offline for six hours during Black Friday”

C

I

A

4

“Ransomware encrypts the file server; staff cannot open documents”

C

I

A

5

“Employee e-mails the HR (Human Resources) folder to a personal address”

C

I

A

6

“Order records altered so that refunds were paid twice”

C

I

A



Real-life example: one order, three properties

LESSON 3

0:24 – 0:36

1 2 3 4 5

One customer order through the web shop — then one employee login

The task

Follow order ORD-1042 (\$129.90) from the customer's phone to the warehouse: where can C, I and A fail, and what protects each? Then name the four checks of one employee login.

How it relates

Each property gets a concrete failure and a concrete protection on BlueFern's own web shop; the login checks appear in the order they happen.

Where it returns

The C, I, A ratings of Exercise 1.1 (Binder Part 1) · the **RBAC** (Role-Based Access Control) matrix of Exercise 2.3 (Part 2) · the identity design of Part 7 · the backup plan of Part 6.



Try it: [examples/L3_order_pipeline_cia_monitor.html](#) — pause at step 7

One customer order, three properties - and the four checks of a login

Order ORD-1042 (\$129.90) travels through BlueFern's web shop. Three incidents show a failure of Confidentiality, Integrity and Availability; then an employee login shows identification, authentication, authorization and accounting (which gives non-repudiation).

Start

Restart

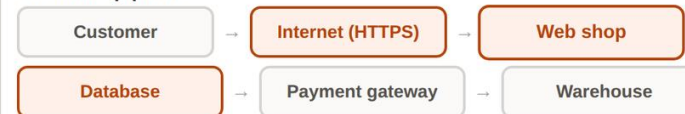
Copy log

Copy code

Download observations (CSV)

Step 7 of 11 - a property just failed; pause and discuss.

The order pipeline



The three properties

Confidentiality		OK
Integrity		OK
Availability		FAILED

Employee login: the four checks

Identification - the user claims an identity (username)

Authentication - the claim is proven (password + MFA code)

Authorization - what this identity may do (role-based rules)

Accounting - the action is recorded (log + signed receipt = non-repudiation)

Execution steps

Step 5 - INCIDENT 2 - an attacker with database access changes the total from \$129.90 to \$1.90. The recomputed hash no longer matches the stored one: the tampering is DETECTED. INTEGRITY FAILED but the failure is visible. Control: hashing and restricted database access (Parts 4 and 7).

Step 6 - The order is restored from the customer's signed confirmation and sent to the payment gateway. Integrity is back to 100 because the correct value is known and verified.

Step 7 - INCIDENT 3 - Black Friday: traffic is 20x normal, the single virtual machine saturates and checkout requests time out. AVAILABILITY FAILS (about \$25,000 per hour). Control: capacity planning, a CDN and DDoS protection (Part 6).



Review & watch — Lesson 3

LESSON 3

0:24 – 0:36

1

2

3

4

5

Five key terms — cover the definition, say it, then check

1 Confidentiality

Information is not disclosed to unauthorized persons, processes or systems. Failure: a disclosure (leak). Protections: encryption (at rest and in transit, e.g. **HTTPS** (HyperText Transfer Protocol Secure)), access control, authentication.

2 Integrity

Information is accurate, complete and not altered without authorization. Failure: an unauthorized modification. Protections: hashing (e.g. **SHA-256** (Secure Hash Algorithm, 256-bit) fingerprints), digital signatures, access control.

3 Availability

Systems and data are accessible and usable on demand by authorized users. Failure: a disruption (outage, unusable slowness). Protections: redundancy, capacity planning, tested backups, denial-of-service protection.

4 Authentication versus authorization

Authentication verifies a claimed identity with factors (know / have / are; two types = **MFA** (Multi-Factor Authentication)). Authorization decides what the verified identity may do, under least privilege, usually through roles (RBAC).

5 Non-repudiation

A party cannot later deny having performed an action. Produced by authentication + accounting (tamper-resistant logs) and, in its strongest form, a digital signature made with a key only the signer holds.



Watch — under 15 min

[The CIA Triad - CompTIA Security+ SY0-701 - 1.2](#)

Professor Messer (Messer Studios) · 5:17

[Authentication, Authorization, and Accounting - CompTIA Security+ SY0-701 - 1.2](#)

Professor Messer (Messer Studios) · 9:04



Self-check — Lesson 3 (1/2)

LESSON 3

0:24 – 0:36

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

1

MCQ (Multiple-Choice Question) — one answer

'Retailer's customer list posted on a public forum' is primarily a failure of:

- a) Confidentiality
- b) Integrity
- c) Availability
- d) Non-repudiation

2

MCQ — one answer

The web shop stores a SHA-256 (Secure Hash Algorithm, 256-bit) hash of every order and recomputes it later to detect changes. Which property does this protect?

- a) Confidentiality
- b) Integrity
- c) Availability
- d) Authorization

3

MCQ — one answer

During Black Friday, a flood of requests makes the web shop unreachable. Which property fails?

- a) Confidentiality
- b) Integrity
- c) Availability
- d) Authentication

4

MCQ — one answer

A warehouse employee's request to open 'Payment reports' is denied because the warehouse role does not include it. This is an example of:

- a) Identification
- b) Authentication
- c) Authorization
- d) Non-repudiation



Self-check — Lesson 3 (2/2)

LESSON 3

0:24 – 0:36

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

5

MSQ (Multiple-Select Question) — select 3

Which of the following are authentication factors? (3)

- a) A username
- b) A password
- c) A job role such as 'warehouse'
- d) A one-time code from an authenticator app on your phone
- e) A log entry with the time of the login
- f) A fingerprint

6

MSQ — select 2

Which mechanisms provide non-repudiation? (2)

- a) Disk encryption on the laptops
- b) A digital signature on the order confirmation
- c) A second server that takes over when the first fails
- d) A firewall rule that blocks port 21
- e) A tamper-resistant log entry recording the user, the time and the action
- f) Antivirus signatures updated daily



The threat landscape: five families

LESSON 4

0:36 – 0:46

1

2

3

4

5

Recognition level today — each family gets its own class later in the term

Threat landscape — the set of threats an organization actually faces at a given time. It changes every year; its main families have been stable for two decades.

1

Malware

Malicious software that damages, disrupts, spies on or takes control of a computer without the owner's consent.

Mainly hits
availability & integrity
(ransomware), confidentiality
(spyware)
Class 5

2

Intrusion

Unauthorized access through a vulnerability, guessed or stolen credentials, or an unprotected path.

Mainly hits
confidentiality & integrity
Classes 3–4

3

Denial of service

Overwhelming a system so that its legitimate users cannot use it.

Mainly hits
availability
Class 6

4

Social engineering

Manipulating people into actions or disclosures that harm security.

Mainly hits
confidentiality first
Class 3

5

Insiders

People with legitimate access who misuse it — or cause harm without intent.

Mainly hits
confidentiality
Class 2 • Sprint 2



Malware and its species

LESSON 4

0:36 – 0:46

1

2

3

4

5

Named by how they spread and what they do

1

Virus

attaches itself to another program or file; needs a person to run that file.

2

Worm

spreads by itself across a network, through a vulnerability, with no person involved.

3

Trojan

presents itself as useful software; does something else once installed.

4

Ransomware

encrypts the victim's data and demands payment for the key.

5

Spyware

collects information — for example keystrokes — and sends it to the attacker.

6

Botnet

a set of infected machines controlled as a group — often used for denial of service.

At BlueFern

Thirty laptops on which everyone has administrator rights · a flat network on which a worm can reach every machine · an untested backup attached to the very server ransomware would encrypt → **Class 5**.



Four more threat families

LESSON 4

0:36 – 0:46

1

2

3

4

5

Intrusion · denial of service · social engineering · insiders

2 Intrusion

Unauthorized access to a system: a vulnerability, **brute force** (trying passwords systematically) or **credential stuffing** (passwords leaked from other sites).

At BlueFern: SSH (Secure Shell) and MySQL open to the Internet · a shared admin password · a guest Wi-Fi that reaches the file server.

3 Denial of service

An attack on availability: the system is overwhelmed so legitimate users cannot use it; **DDoS** (Distributed Denial of Service) when the traffic comes from many machines at once (a botnet).

At BlueFern: One web-shop server with no traffic protection — Black Friday week is worth about \$25,000 per hour.

4 Social engineering

Manipulating people, not software: **phishing** (fraudulent message), **pretexting** (false story), **baiting** (a tempting object, such as a **USB** (Universal Serial Bus) drive in the parking lot).

At BlueFern: No awareness training · staff roles published on social media · a receptionist never told not to give out the admin password.

5 Insiders

People with legitimate access: **malicious** (copies the customer spreadsheet before resigning) or **negligent** (posts a photo with the Wi-Fi password readable on the wall).

At BlueFern: Everybody reads everything on the file server · access never revoked · USB ports open.



Threat landscape map of BlueFern

LESSON 4

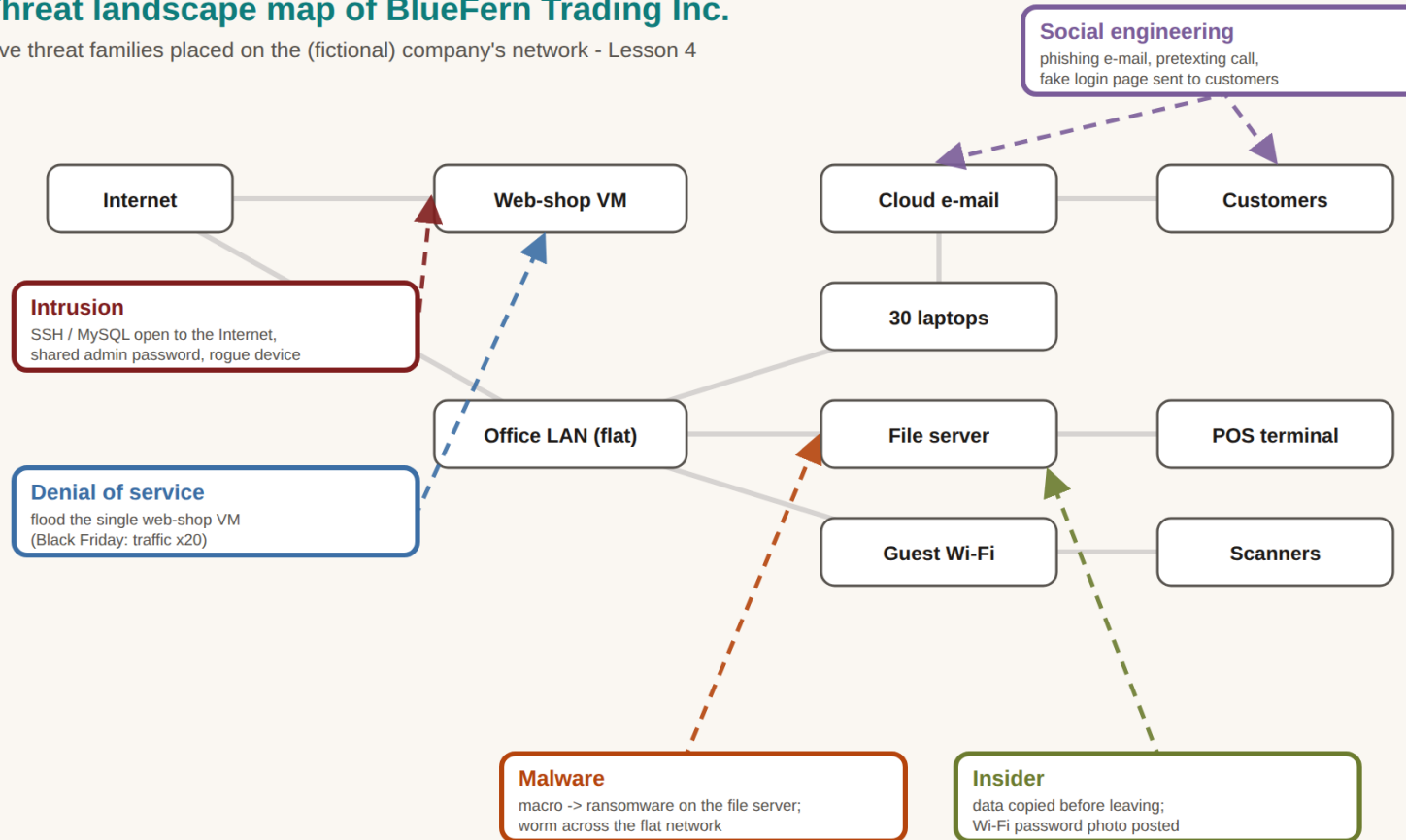
0:36 – 0:46

1 2 3 4 5

Five threat families placed on the (fictional) company's network

Threat landscape map of BlueFern Trading Inc.

Five threat families placed on the (fictional) company's network - Lesson 4



Cyber.SoHo - CS 474 Class 1 - Lesson 4 - recognition level; each family has its own class later

How to read it

- Grey boxes: BlueFern's network, simplified — everything sits on one flat office **LAN** (Local Area Network).
- Coloured boxes: the five families and their typical way in.
- Dashed arrows: the asset each family hits first.
- Recognition level today; each family has its own class later.



Who is behind it — and which family?

LESSON 4

0:36 – 0:46

1

2

3

4

5

Threat actors, then a 2-minute micro-activity: shout the family

Threat actors

Opportunistic individuals

downloaded tools

Organized crime

ransomware is a business

Hacktivists

a political message

Nation-state groups

state objectives

Insiders

access they already have

Your turn: which family is it?

?

“The file server shows a note asking for 40,000 dollars in cryptocurrency.”

?

“200,000 requests per second from thousands of addresses hit the web shop.”

?

*“A caller who says he is from the bank asks the **CFO** (Chief Financial Officer) to confirm the login code that was just sent.”*



Real-life example: one week of security events

LESSON 4

0:36 – 0:46

1 2 3 4 5

Ten events, five families — the counts feed Exercise 1.2

The task

Read ten events of one week at BlueFern; classify each into a family, name the asset hit and the property affected, propose the first countermeasure, and count the events per family.

How it relates

The five families applied to realistic events, each tied to an asset (Lesson 1) and a property (Lesson 3).

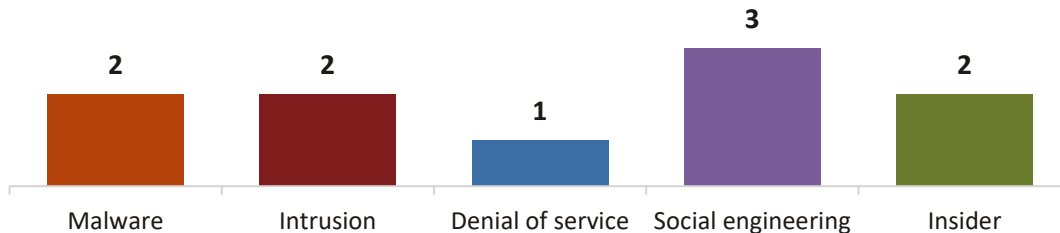
Where it returns

Exercise 1.2 (top-5 threats, Binder Part 1) · Part 3 attack classification · Part 5 malware playbook · Part 6 detection and risk register.



Try it: [examples/L4_event_stream_classifier.html](#) — Start · Pause · Download CSV (Comma-Separated Values)

Events per family — one week



One week at BlueFern - ten events, five threat families

Each step reads one event from the week, classifies it into a family (malware, intrusion, denial of service, social engineering, insider), names the targeted asset and the property affected, and proposes the first countermeasure. The counts feed Exercise 1.2 (top-5 threats).

Start

Restart

Copy log

Copy code

Download classified events (CSV)

Finished - press Restart to run again.

Event feed (newest on top)

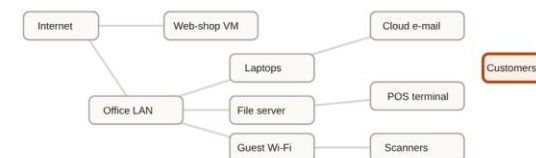
Social eng. Fri 17:30 - Customers receive an e-mail with a fake 'BlueFern' login page asking them to 'confirm their account'.

Malware Fri 08:45 - A ransom note appears on the file server; documents are encrypted and unreadable.

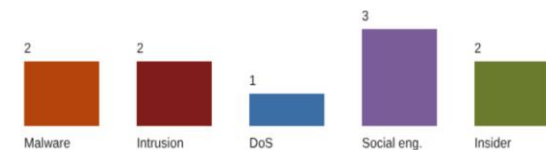
Intrusion Thu 13:00 - An unknown laptop joins the guest Wi-Fi and reaches the file server's shared folders.

Insider Thu 10:00 - Marketing posts a screenshot of a social media chat on the company website.

Where it hits - BlueFern's network (simplified)



Events per family



Execution steps

property affected = A, I
why: Ransomware is malware that encrypts data to extort payment (Binder Part 5 playbook).
first countermeasure: Tested off-line backups, endpoint protection, removal of local admin rights

Step 10 [Fri 17:30] Customers receive an e-mail with a fake 'BlueFern' login page asking them to 'confirm their account'.
family = Social eng. | target = Customers | property affected = C
why: Customers are deceived into giving their credentials - phishing using BlueFern's name.
first countermeasure: Customer warning, e-mail authentication (SPF/DKIM/DMARC), takedown request

Done. Week totals: Social eng. (3), Malware (2), Intrusion (2), Insider (2), DoS (1). Use the counts and the targets to argue your top-5 threats in Exercise 1.2 (Binder Part 1).



Review & watch — Lesson 4

LESSON 4

0:36 – 0:46

1

2

3

4

5

Five key terms — cover the definition, say it, then check

1 Malware

Malicious software that damages, disrupts, spies on or takes control of a computer without consent. Species: virus (needs a host file and a person), worm (spreads by itself), trojan (pretends to be useful), ransomware (encrypts and extorts), spyware (collects information), botnet (infected machines controlled as a group).

2 Intrusion

Unauthorized access to a system - through a vulnerability, through guessed or stolen credentials (brute force, credential stuffing) or through an unprotected network path. At BlueFern: **SSH** (Secure Shell) and MySQL open to the Internet, a shared admin password.

3 Denial of service (DoS / DDoS)

An attack on availability: the system is overwhelmed with traffic or requests so that legitimate users cannot use it. Distributed (DDoS) when the traffic comes from many machines at once, typically a botnet.

4 Social engineering

Manipulating people into actions or disclosures that harm security: phishing (fraudulent messages), pretexting (a false story to obtain information), baiting (a tempting object such as a dropped **USB** (Universal Serial Bus) drive). It attacks judgement, not software.

5 Insider threat

A person with legitimate access who harms security: malicious (on purpose - copying data before leaving) or negligent (without intent - posting a photo that shows the Wi-Fi password). Controls: least privilege, leave procedure, USB control.



Watch — under 15 min

[Hackers & Cyber Attacks - Crash Course Computer Science #32](#)

Crash Course / PBS (Public Broadcasting Service) Digital Studios · about 12 min

[An Overview of Malware - CompTIA Security+ SY0-701 - 2.4](#)

Professor Messer (Messer Studios) · 6:06



Self-check — Lesson 4 (1/2)

LESSON 4

0:36 – 0:46

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

1

MCQ (Multiple-Choice Question) — one answer

An e-mail pretending to be an overdue invoice persuades an employee to enable macros in the attachment. The technique used to obtain the click is:

- a) Denial of service
- b) Social engineering (phishing)
- c) Insider threat
- d) Intrusion by brute force

2

MCQ — one answer

What distinguishes a distributed denial-of-service (DDoS) attack from a simple DoS (Denial of Service) attack?

- a) It targets a database instead of a web server
- b) The flood comes from many machines at once, typically a botnet
- c) It steals data while overloading the server
- d) It uses a virus to crash the operating system

3

MCQ — one answer

Ransomware belongs to which threat family?

- a) Malware
- b) Social engineering
- c) Insider threat
- d) Denial of service

4

MCQ — one answer

A marketing employee posts a showroom photo on social media in which the Wi-Fi password on the wall is readable. This is best classified as:

- a) A malicious insider
- b) An intrusion
- c) Malware
- d) A negligent insider



Self-check — Lesson 4 (2/2)

LESSON 4

0:36 – 0:46

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

5

MSQ (Multiple-Select Question) — select 3

Which of the following are social-engineering techniques? (3)

- a) Phishing
- b) A SYN flood
- c) Worm propagation across a network
- d) Pretexting
- e) Baiting
- f) Brute-force password guessing

6

MSQ — select 2

Which of these events from the BlueFern week are malware events? (2)

- a) 3,200 failed **SSH** (Secure Shell) logins from one address
- b) A caller asking the receptionist for the administrator password
- c) A worm spreading across the flat network and slowing the scanners
- d) 200,000 requests per second against the web shop
- e) A finance clerk copying the customer spreadsheet to a **USB** (Universal Serial Bus) drive
- f) Documents encrypted on the file server with a ransom note



Security is a process

LESSON 5

0:46 – 1:00

1

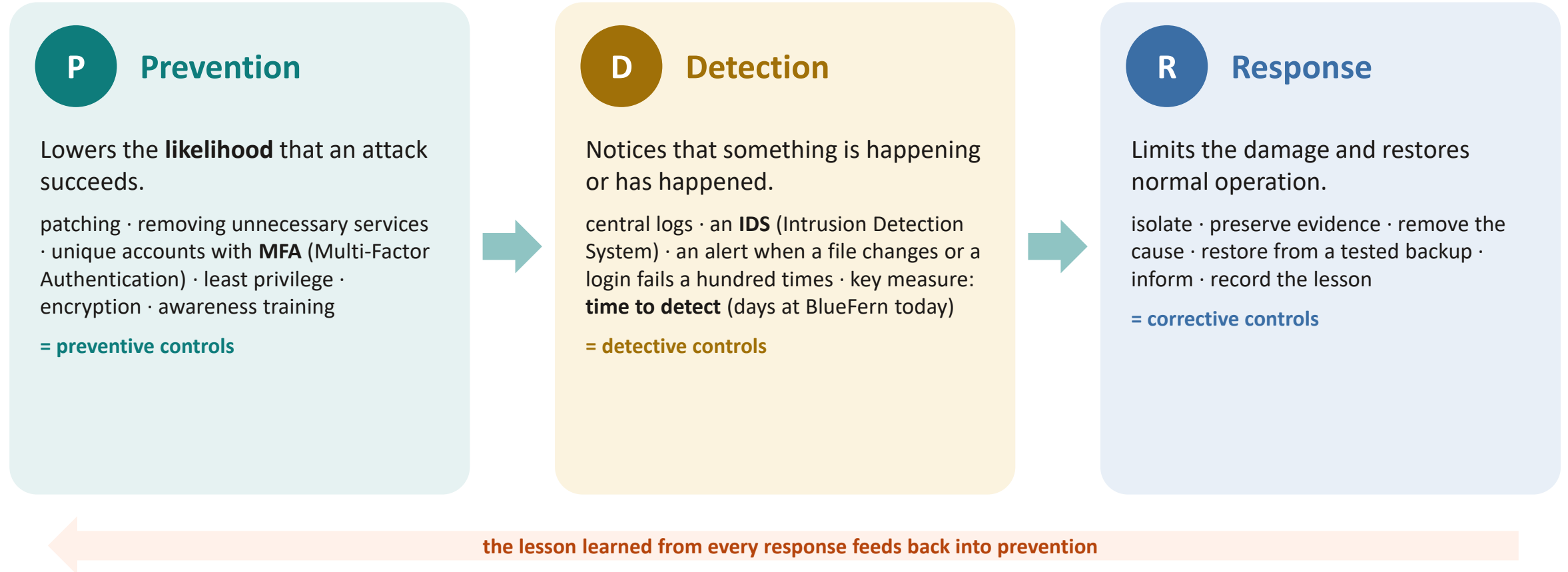
2

3

4

5

Prevention · detection · response — and back to prevention



Formal versions: **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-61 (incident response, Class 6) · **NIST CSF** (Cybersecurity Framework) 2.0 — Govern, Identify, Protect, Detect, Respond, Recover.



Defence in depth

LESSON 5

0:46 – 1:00

1

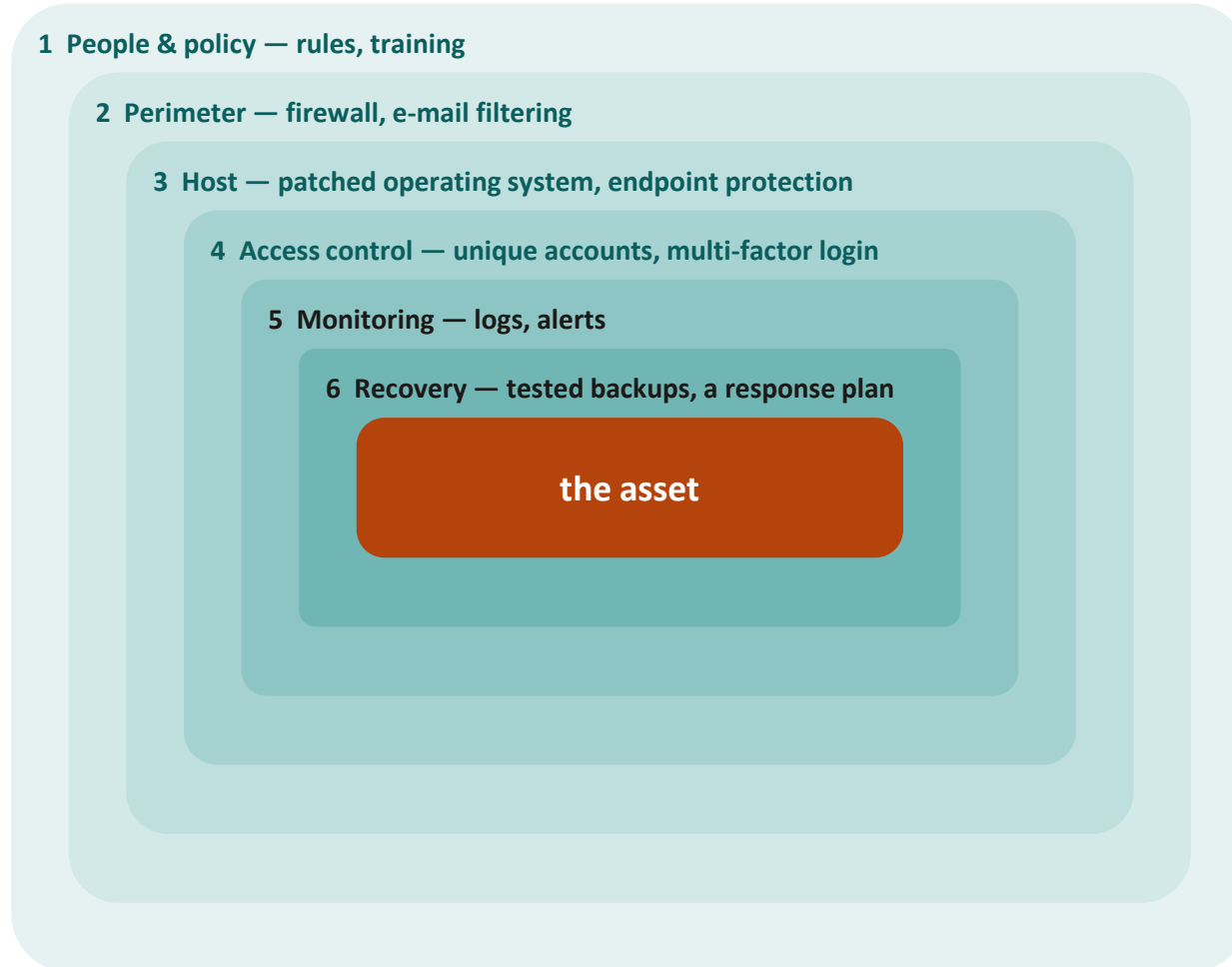
2

3

4

5

Several independent layers — the failure of one does not defeat the whole



- **Defence in depth** — the design principle that protection is built from several independent layers, so that the failure of one layer does not defeat the whole.
- An attacker who gets past one layer must still get past the next — and every layer gives the defenders another chance to notice.

BlueFern today — the counter-example

One flat network, one shared password, no logging, one backup attached to the server it protects: a single phishing e-mail passes every layer because there are no layers.



The cycle and the layers

LESSON 5

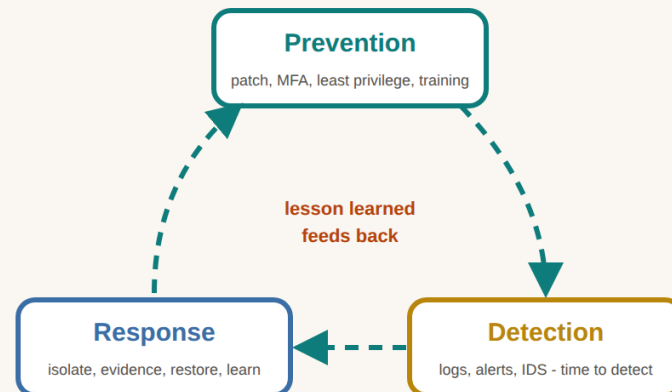
0:46 – 1:00

1 2 3 4 5

Prevention → detection → response, and defence in depth

Security is a process - and a set of layers

Left: the three activities repeat for as long as the system exists. Right: defence in depth (Lesson 5)



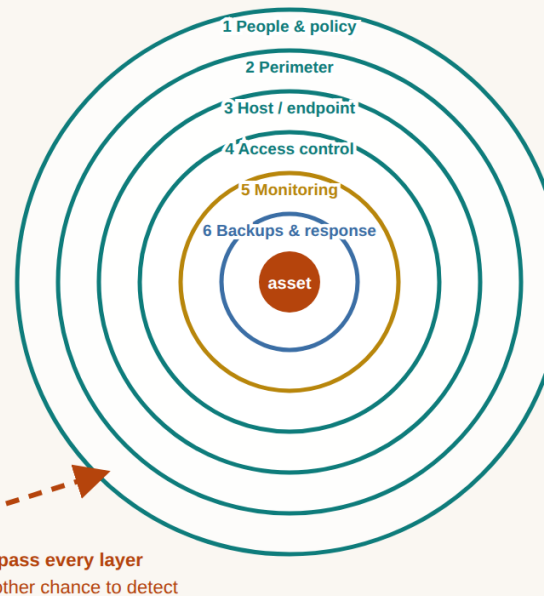
NIST CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond, Recover

NIST SP 800-61: the incident-response lifecycle (applied in Class 6)

BlueFern today: one flat network, one shared password, no logs, one backup on the same server - a single phishing e-mail passes every layer because there are no layers.

No permission, no testing: Criminal Code s. 342.1 (CA) - CFAA 18 U.S.C. § 1030 (US) - Directive 2013/40/EU (EU) - LO 10/1995 (ES)

Cyber.SoHo - CS 474 Class 1 - Lesson 5



How to read it

- Left: the three activities repeat for as long as the system exists.
- The lesson learned feeds back into prevention.
- Right: six layers around the asset — layer 1 is the first one an attacker meets.
- Each layer is another chance to detect.
- Bottom: BlueFern today has no layers.

Real-life example: one attack, two networks

The same phishing e-mail against BlueFern today and against a hardened BlueFern

The task

Run one phishing attack — an e-mail whose macro installs ransomware — against BlueFern today and against a BlueFern with six layers; record each layer: passed, prevented, detected, responded.

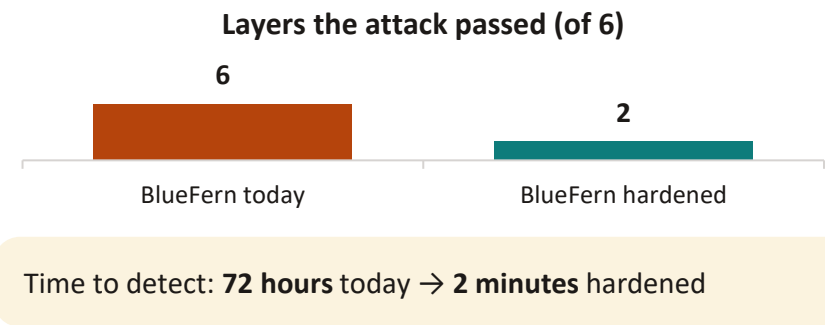
How it relates

Prevention, detection and response as phases of one incident; defence in depth as the reason the hardened company survives.

Where it returns

Binder Parts 2, 4, 5, 6 and 8 — one or two layers each.

Try it: [examples/L5_defence_in_depth_simulator.html](#) — gate, then Start



Defence in depth - one phishing attack, two networks

The same attack (a phishing e-mail whose macro installs ransomware) runs against BlueFern as it is today (no layers) and against a hardened BlueFern (six layers). Watch where the attack is prevented, where it is detected and how the response ends.

Authorization gate. This simulation runs only against the fictional BlueFern lab scenario. Real testing needs written permission from the system owner first - no permission, no testing (Criminal Code s. 342.1).

Start

Restart

Copy log

Copy code

Download layer results (CSV)

Finished - press Restart to run again.

	1 People & policy training, rules	2 Perimeter firewall, e-mail filter	3 Endpoint patches, macros off, EDR	4 Access control unique accounts, MFA	5 Monitoring logs, alerts	6 Backups & response restore, playbook
BlueFern today	passed through	passed through	passed through	passed through	passed through	passed through
BlueFern hardened	passed through	passed through	PREVENTED	not reached	DETECTED	RESPONSE

BlueFern today

Layers passed: 6
Prevented at: -
Detected at: 6 Backups & response (ransom note)
Time to detect: 72 hours
Phase: Prevention (failing)

BlueFern hardened

Layers passed: 2
Prevented at: 3 Endpoint
Detected at: 5 Monitoring
Time to detect: 2 minutes
Phase: Response / recovery

No permission, no testing (1/2)

LESSON 5

0:46 – 1:00

1

2

3

4

5

The law in Canada — Criminal Code

§

Criminal Code s. 342.1

Obtaining a computer service, or intercepting a function of a computer system, **without authorization** — up to ten years of imprisonment.

§

Criminal Code s. 342.2

Making, possessing or distributing a **device or software** designed for that purpose.

§

Criminal Code s. 430(1.1)

Altering data or interfering with its lawful use — where **denial-of-service** activity falls.

§

Criminal Code s. 184

Intercepting private communications — where capturing other people's network traffic falls.

Lawful in this course for one reason only: lab systems + the fictional BlueFern scenario + **explicit authorization**. · [Criminal Code s. 342.1 — Justice Laws Website](#)



No permission, no testing (2/2)

Other jurisdictions, privacy law — and three course rules, effective now

LESSON 5

0:46 – 1:00

1

2

3

4

5

They can apply at the same time — the Internet has no borders

- United States: [Computer Fraud and Abuse Act, 18 U.S.C. § 1030](#)
- European Union: [Directive 2013/40/EU](#) — implemented by each member state
- Spain: [Ley Orgánica 10/1995, Código Penal](#)

Privacy law — duties of whoever holds personal data (Class 2)

- Canada: [PIPEDA — Office of the Privacy Commissioner](#)
- Québec: [Law 25 — Commission d'accès à l'information](#)
- European Union: [General Data Protection Regulation](#)

Three rules for this course

1

Never scan, test or attack a system that is not the designated lab system — not the campus network, not your home Wi-Fi, not a “harmless” website.

2

No **OSINT** (Open-Source Intelligence) on real people or real organizations — BlueFern is fictional on purpose.

3

Not certain you are authorized? Then you are not. **Stop and ask.**

[Cyber.SoHo Legal Notice, Terms of Use & Acceptable Use Policy \(v2.0\)](#) — your written acknowledgement comes before the first laboratory.



How the course runs — the details

LESSON 5

0:46 – 1:00

1 2 3 4 5

Rhythm · individual Binder · milestones · tools



1:2:2 every Thursday

this lecture hour · two hours of guided project work in teams of two or three · two hours at home

The Binder is individual

every student submits every Part and does every computation

Tools

a laptop · the course **LMS** (Learning Management System) · the textbook (Easttom, chapter 1 this week) · a virtualization environment for the labs from Class 4 (announced before then)

Exams

Respondus LockDown Browser — you test it in Class 8



Fun quiz + Zen break

4 minutes · show of hands · no marks

LESSON 5

0:46 – 1:00

1

2

3

4

5

?

What are the three assessment weights?

?

On which day, and at what time, is every Binder Part due?

?

What is the date of the Mid-Term?

The answers are on the “How this course works” slides of Lesson 1 — we check them together after the show of hands.

2 min

Zen break

- Stand up.
- Three slow breaths.
- Look at something six metres away.
- Stretch.
- Project work starts after the break.



Review & watch — Lesson 5

LESSON 5

0:46 – 1:00

1 2 3 4 5

Five key terms — cover the definition, say it, then check

1 Prevention, detection, response

The three repeating activities of security: prevention lowers the likelihood of a successful attack (preventive controls); detection notices the event (detective controls, measured by the time to detect); response limits the damage and restores operation (corrective controls), and the lesson learned feeds back into prevention.

2 Defence in depth

Protection built from several independent layers - policy and people, perimeter, host, access control, monitoring, recovery - so that the failure of one layer does not defeat the whole, and each layer gives another chance to detect.

3 Time to detect

The interval between the first malicious action and the moment the organization knows about it. Days at BlueFern today (no central logs, nobody watching); minutes with endpoint alerts and a log collector.

4 No permission, no testing

Scanning, testing or attacking any system without the owner's explicit (written) authorization is a criminal offence whatever the intent - Criminal Code s. 342.1 in Canada, the **CFAA** (Computer Fraud and Abuse Act) in the **US** (United States), Directive 2013/40/EU in the **EU** (European Union). In this course: designated lab systems and the fictional BlueFern scenario only; no **OSINT** (Open-Source Intelligence) on real people or organizations.

5 The 1:2:2 rhythm and the milestones

Every Thursday: 1 h lecture, 2 h guided project work in teams, 2 h at home. The Binder is individual. Milestone 1 = Mid-Term, Nov 19 (Binder v1, Parts 1-7, due Nov 18); Milestone 2 = Final, Jan 21 (Parts 1-11, due Jan 13); showcase Jan 14. Weights 30 / 30 / 40.

Watch — under 15 min

[Security Controls - CompTIA Security+ SY0-701 - 1.1](#)

Professor Messer (Messer Studios) · 11:49

[Defense in Depth - CompTIA Network+ N10-008 - 4.1](#)

Professor Messer (Messer Studios) · 10:02



Self-check — Lesson 5 (1/2)

LESSON 5

0:46 – 1:00

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

1

MCQ (Multiple-Choice Question) — one answer

Restoring the file server from a tested off-line backup after a ransomware attack belongs to which activity?

- a) Prevention
- b) Detection
- c) Response (and recovery)
- d) Authorization

2

MCQ — one answer

Which of the following is a DETECTIVE control?

- a) A firewall rule that blocks port 21 from the Internet
- b) Reviewing the central log for repeated failed logins
- c) Disk encryption on the staff laptops
- d) A password policy requiring 14 characters

3

MCQ — one answer

'Defence in depth' means:

- a) Buying the strongest firewall available
- b) Several independent layers of protection, so that the failure of one does not defeat the whole
- c) Keeping the network hidden from the Internet
- d) Relying on physical security only

4

MCQ — one answer

A classmate proposes scanning the café's Wi-Fi network 'for practice'. Legally, this is:

- a) Acceptable because you are a security student
- b) Acceptable as long as nothing breaks
- c) Potentially a criminal offence (for example Criminal Code s. 342.1) without the owner's written authorization
- d) Allowed outside class hours



Self-check — Lesson 5 (2/2)

LESSON 5

0:46 — 1:00

1

2

3

4

5

FORMATIVE — for practice only · not summative · it does NOT count toward your grade

5

MSQ (Multiple-Select Question) — select 3

Which of the following are **PREVENTIVE** controls? (3)

- a) Patching the web-shop server
- b) An alert from the intrusion detection system
- c) Requiring **MFA** (Multi-Factor Authentication) on the **VPN** (Virtual Private Network)
- d) The ransomware response playbook
- e) Weekly review of the login logs
- f) Disabling macros in documents that come from the Internet

6

MSQ — select 3

Which actions require written authorization from the system owner **BEFORE** you do them? (3)

- a) Reading chapter 1 of the textbook
- b) Port-scanning a server
- c) Drawing BlueFern's network map from the company profile
- d) Running a vulnerability scanner against a web application
- e) Computing a risk score on paper
- f) Capturing network traffic on a shared Wi-Fi



Binder Part 1 — what it will ask

WRAP-UP

1

2

3

4

5

Asset Inventory & First Threat Picture · summary only — the exercise sheet is provided separately

Exercise 1.1

Asset inventory

At least **12** BlueFern assets — each classified (hardware, software, data, people, process), with a named owner and a Low / Medium / High rating of the impact of a C, I and A failure.

Exercise 1.2

Threat brainstorm

The **five threats** most likely to hurt BlueFern this year — one sentence each on why.

Exercise 1.3

Project Binder set-up

Set up from the template: your name, your team and a **three-line first impression** of the state of the company.



Due Wednesday, September 30, 2026 · 23:59 — on the LMS (Learning Management System)

Every later Part (risk register, scan priorities, incident plan, architecture) refers back to this inventory — and exam questions ask for the same work on a similar company.



Useful links (1/2)

WRAP-UP

1

2

3

4

5

Rules, law and official agencies

- [Cyber.SoHo - Legal Notice, Terms of Use and Acceptable Use Policy \(v2.0\)](#)
 - Authorization first; permitted and prohibited activities; code of ethics
- [Criminal Code of Canada, section 342.1 \(Justice Laws Website\)](#)
 - Unauthorized use of a computer — the Canadian offence
- [US Computer Fraud and Abuse Act, 18 U.S.C. § 1030 \(Cornell LII\)](#)
 - The United States federal computer-crime statute
- [EU Directive 2013/40/EU on attacks against information systems \(EUR-Lex\)](#)
 - The European framework on attacks against information systems
- [Spain - Ley Orgánica 10/1995, Código Penal \(BOE\)](#)
 - The Spanish Criminal Code (computer offences)
- [PIPEDA - Office of the Privacy Commissioner of Canada](#)
 - Canada's federal private-sector privacy law
- [Commission d'accès à l'information du Québec \(Law 25\)](#)
 - Québec's privacy regulator — Law 25
- [EU General Data Protection Regulation \(EUR-Lex\)](#)
 - The European Union privacy regulation for personal data
- [Canadian Centre for Cyber Security](#)
 - Canada's national authority: alerts and baseline controls
- [Get Cyber Safe \(Government of Canada\)](#)
 - Plain-language guidance: phishing, passwords, multi-factor login
- [Canadian Anti-Fraud Centre](#)
 - Where phishing and fraud are reported in Canada
- [CISA - Cybersecurity and Infrastructure Security Agency](#)
 - United States agency: advisories and exploited vulnerabilities
- [VirusTotal - URL check](#)
 - Check any link or download before you open it

Every address is an official site. In doubt about any link? Check it first with [VirusTotal — URL check](#).



Useful links (2/2)

WRAP-UP

1

2

3

4

5

Standards, knowledge bases, courses and the textbook

- [NIST - National Institute of Standards and Technology](#)
 - The reference vocabulary of the profession (standards, guides)
- [NIST Cybersecurity Framework \(CSF\) 2.0](#)
 - Govern, Identify, Protect, Detect, Respond, Recover
- [NIST SP 800-61 - Incident Response Recommendations and Considerations](#)
 - The incident-response lifecycle, applied in Class 6
- [NIST Computer Security Resource Center - Glossary](#)
 - Official definitions: asset, threat, vulnerability, risk, control
- [CVE - Common Vulnerabilities and Exposures](#)
 - The public catalogue of vulnerabilities (e.g. CVE-2011-2523)
- [NVD - National Vulnerability Database](#)
 - Severity scores for every catalogued vulnerability (Class 4)
- [MITRE ATT&CK](#)
 - Attacker tactics and techniques (Class 3)
- [OWASP - Open Worldwide Application Security Project](#)
 - Web-application security and its Top 10 risk list (Class 10)
- [ISO/IEC 27001 - Information security management](#)
 - The international standard for security management
- [ENISA - European Union Agency for Cybersecurity](#)
 - The annual European threat-landscape report
- [Professor Messer - free CompTIA Security+ SY0-701 course](#)
 - Free Security+ course index with the video runtimes
- [Crash Course Computer Science #31 - Cybersecurity \(official page\)](#)
 - The official page of the Lesson 1 video
- [Pearson - Computer Security Fundamentals, 4th edition \(Easttom\)](#)
 - Publisher of the textbook (Easttom, 4th edition)

Every address is an official site. In doubt about any link? Check it first with [VirusTotal — URL check](#).



Before you leave

WRAP-UP 1 2 3 4 5

Exit ticket · at home · next Thursday

Exit ticket — the last two minutes of the session

- One term from today you can define without notes.
- One term you still cannot.
- On the card or in the **LMS** (Learning Management System) form.

At home — 2 hours

- Read Easttom, chapter 1 (types of threats, basic terminology, concepts and approaches).
- Finish **Binder Part 1** — due Wednesday, September 30, 23:59.
- Check that your laptop can run the lab environment (announced before Class 4).

Next Thursday · October 1, 2026

Class 2 — Rules of the Game: Security Models, Policies & the Network We Defend



Cyber.SoHo — Educational Hub

From the Industry to the Classroom

Educational material - Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved. For use in an isolated, authorized lab environment only, against the targets the course designates - here, the fictional BlueFern Trading Inc. scenario. Applying the tools or techniques described in this course to any other system, network or data without the owner's express written authorization may be a criminal offence (Criminal Code, ss. 342.1, 342.2, 430(1.1) and 184; US CFAA 18 U.S.C. § 1030; EU Directive 2013/40/EU; Spain Ley Orgánica 10/1995) and is strictly prohibited. You alone are responsible for your actions and your equipment.

Full terms: [Cyber.SoHo Legal Notice, Terms of Use & Acceptable Use Policy \(v2.0\)](#)

